



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-0257 Palo Alto Networks PAN-OS Authentication Bypass Vulnerability

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-05-29
Version	1.1
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-0257 Palo Alto Networks PAN-OS Authentication Bypass Vulnerability - CVE / Vulnerability Threat Intelligence Report

Published: 2026-05-29 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-0257 Palo Alto Networks PAN-OS Authentication Bypass Vulnerability

1. Executive Summary

CVE-2026-0257 is an actively exploited authentication-bypass vulnerability in Palo Alto Networks PAN-OS GlobalProtect portal and gateway components. Palo Alto Networks, the CVE Program, NVD, and CISA all align on the core risk: an unauthenticated attacker can bypass security restrictions and establish an unauthorized VPN connection on vulnerable appliances. CISA added the issue to the Known Exploited Vulnerabilities (KEV) catalog on 2026-05-29, making this both a patching emergency and a retrospective-hunting priority for organizations that expose GlobalProtect.

The important qualifier is configuration. Palo Alto states the issue affects firewalls with GlobalProtect portal or gateway configured when authentication override cookies are enabled and the certificate used for those cookies is configured in an unsafe way. That means not every PAN-OS deployment is equally exposed, but edge-facing appliances that use authentication override should be treated as high-risk until configuration and version state are verified.

Secondary reporting from Rapid7 and Unit 42 raises the operational urgency further. Rapid7 observed successful exploitation across multiple customer environments beginning no later than 2026-05-17 and documented attacker source infrastructure, spoofed MAC usage, and forged-cookie behavior. Unit 42 separately reported active exploitation activity aimed at GlobalProtect access and urged defenders to hunt for successful login events tied to the campaign indicators.

Confirmed facts:

- CVE ID: CVE-2026-0257
- Vendor: Palo Alto Networks
- Product: PAN-OS GlobalProtect portal and gateway
- Vulnerability class: Authentication bypass
- Primary impact: Unauthorized VPN connection establishment
- CWE: CWE-565 Reliance on Cookies without Validation and Integrity Checking
- CVSS v3.1: 9.1 Critical
- CVSS vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
- Vendor CVSS v4.0: 7.8 High
- KEV date added: 2026-05-29
- KEV due date for FCEB agencies: 2026-06-01
- Affected deployment precondition: Authentication override cookies enabled with unsafe certificate reuse / configuration
- Not impacted: Panorama and Cloud NGFW

Analyst assessment:

- Treat internet-facing GlobalProtect exposure as urgent even if the deployment is thought to be “partially mitigated” through segmentation or restricted user populations.
- Assume active scanning and opportunistic exploitation are ongoing because the flaw is in KEV and public technical analysis plus validation tooling now exist.
- Prioritize both remediation and compromise assessment; successful exploitation can grant an attacker a trusted foothold through the enterprise VPN edge.

2. Vulnerability Metadata

Field	Value
CNA / vendor	Palo Alto Networks
CVE Program public date	2026-05-13
NVD published date	2026-05-13

NVD last modified at review time	2026-06-01
CISA KEV date added	2026-05-29
CISA KEV due date	2026-06-01
Product family	PAN-OS / GlobalProtect
Exposed components	GlobalProtect portal and gateway
Not impacted products explicitly called out by vendor	Panorama and Cloud NGFW
Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality / Integrity / Availability impact	High / High / None (NVD CVSS v3.1)
Vendor weakness mapping	CWE-565 Reliance on Cookies without Validation and Integrity Checking
PAN-OS 12.1	affected below 12.1.4-h6 and 12.1.7 depending on branch
PAN-OS 11.2	affected below 11.2.4-h17, 11.2.7-h14, 11.2.10-h7, and 11.2.12 depending on branch
PAN-OS 11.1	affected below 11.1.4-h33, 11.1.6-h32, 11.1.7-h6, 11.1.10-h25, 11.1.13-h5, and 11.1.15 depending on branch
PAN-OS 10.2	affected below 10.2.7-h34, 10.2.10-h36, 10.2.13-h21, 10.2.16-h7, and 10.2.18-h6 depending on branch
Prisma Access 11.2.0	affected below 11.2.7-h13 according to vendor guidance
Prisma Access 10.2.0	affected below 10.2.10-h36 according to vendor guidance

Key metadata: Affected-version guidance reflected in Palo Alto and CVE Program data: Operational implications:

- Exposure depends on both software version and the specific GlobalProtect authentication-override configuration.
- The vulnerable surface sits on a security boundary appliance that commonly faces the internet or broad VPN address pools.
- A successful bypass can provide an attacker with a path that looks like legitimate remote access rather than a noisy crash or brute-force event.

3. Source Review & Confidence

Primary-source basis: Secondary-source basis:

Source	Contribution	Confidence
Vendor advisory	Palo Alto describes CVE-2026-0257 as an authentication bypass in PAN-OS GlobalProtect portal and gateway	High-confidence primary source for product impact, remediation, configuration

	components that	preconditions, and ven
Government advisory / KEV catalog entry	CISA lists CVE-2026-0257 as a known exploited vulnerability added on 2026-05-29 with a due date of 2026-06-01 and direct	High-confidence primary source for active-exploitation status and remediation urgency.
Government vulnerability database API	NVD provides the normalized CVE description, CVSS v3.1 9.1 Critical scoring, CVSS v4 vendor metrics, CWE-565 mapping, an	High-confidence primary source for normalized scoring, weakness mapping, and machine-readable enrich
CVE Program API	The CVE Program record confirms Palo Alto Networks PAN-OS as the affected product family and captures affected version b	High-confidence primary source for canonical CVE metadata and version-branch scoping.
Secondary reporting / incident-response field analysis	Rapid7 observed exploitation across numerous customer environments, traced the earliest observed exploitation to 2026-05	Secondary source used for exploitation context, hunt pivots, and example indicators rather than cano
Secondary reporting / vendor threat-intelligence brief	Unit 42 reported active exploitation activity against GlobalProtect, urged defenders to hunt for successful login events	Secondary source used to corroborate active exploitation and hunt priorities.
Secondary database summary	GitHub Advisory Database restates the vulnerability description and links back to NVD, Palo Alto, and CISA references.	Secondary corroborating source only; not used as the authoritative basis for remediation decisions.

Confidence assessment:

4. Vulnerability Details

Palo Alto describes CVE-2026-0257 as an authentication-bypass issue in the GlobalProtect portal and gateway. In the affected configuration, an attacker can bypass security restrictions and establish an unauthorized VPN connection without valid credentials. The vendor explicitly notes that Panorama and Cloud NGFW are not impacted.

The key technical condition is the use of authentication override cookies. This GlobalProtect feature allows a previously authenticated user to present a cookie on future requests instead of re-entering credentials. Palo Alto states the risk exists when authentication override is enabled and a specific certificate configuration is present. Rapid7's technical analysis provides additional context: if the certificate used to protect authentication override cookies is improperly reused with another feature such as the portal or gateway HTTPS service, an unauthenticated attacker may be able to obtain the relevant public key material and forge cookies that the appliance accepts.

For defenders, the practical result is more important than the exact cryptographic failure mode. A compromised outcome is not simply a web-session bypass; it can become a successful VPN login path that grants an adversary remote access from the network edge. That makes this vulnerability materially more dangerous than the vendor's lower-seeming v4 severity might imply when viewed out of context.

5. Attack Scenarios

Scenario 1: Internet-facing GlobalProtect gateway compromise

- An attacker identifies an exposed GlobalProtect portal or gateway on a vulnerable PAN-OS branch.
- The attacker determines or assumes that authentication override is enabled and that the cookie-protection certificate configuration is unsafe.
- A forged authentication cookie is accepted by the appliance, allowing the attacker to establish an unauthorized VPN connection.

- The attacker uses that foothold for internal reconnaissance, credential abuse, or access to sensitive internal services.

Scenario 2: Targeted access against a high-value enterprise VPN edge

- A threat actor focuses on a specific organization known to rely on Palo Alto remote access infrastructure.
- Public-facing TLS and portal behavior are used to evaluate exploitability.
- The actor attempts forged-cookie logins that may initially appear as successful GlobalProtect authentication events rather than obvious exploit payload delivery.
- If the tunnel is established, the actor gains access resembling a legitimate remote user or administrative path.

Scenario 3: Opportunistic post-KEV exploitation

- Attackers use public advisories, KEV inclusion, and published validation tooling to quickly triage targets.
- Vulnerable appliances that were left unpatched after the 2026-05-13 disclosure window become likely targets.
- Even unsuccessful attempts may leave suspicious cookie-authentication telemetry that defenders can still hunt retrospectively.

6. Threat Landscape & Exploitation Status

CISA added CVE-2026-0257 to KEV on 2026-05-29. That is the strongest public signal that exploitation has been confirmed in the wild and should move this issue out of routine patch management and into emergency remediation.

Palo Alto states it became aware of limited exploit attempts on unpatched PAN-OS devices without mitigations applied. Rapid7 reported observing exploitation across numerous customer environments, with the earliest observed exploitation on 2026-05-17. Unit 42 separately published a threat brief on active exploitation and advised defenders to hunt for successful login events tied to the campaign indicators.

Rapid7's observations matter because they show real-world intrusion patterns rather than only theoretical exploitability. In their reporting, some victims saw successful forged-cookie authentication without a full tunnel being established, while others saw VPN IP assignment and internal-network access. That means defenders should not narrowly scope compromise assessment only to appliances where a full VPN session is already obvious; suspicious cookie-authentication success events themselves may be meaningful evidence of attempted or partial compromise.

CISA lists `knownRansomwareCampaignUse` as `Unknown`, so this review does not tie the flaw to a specific ransomware operation. Even without ransomware confirmation, a VPN-edge authentication bypass should be treated as a high-impact initial-access vector with downstream risk for lateral movement, data access, and persistence.

7. Affected Products and Exposure

Confirmed product impact:

- PAN-OS GlobalProtect portal and gateway on affected 10.2, 11.1, 11.2, and 12.1 branches as scoped in Palo Alto's advisory and CVE Program data
- Prisma Access branches with vendor-published fixed versions noted in the advisory
- Not impacted: Panorama and Cloud NGFW

Highest-priority exposure classes:

- Internet-facing GlobalProtect portals and gateways
- Remote-access appliances serving privileged administrative or contractor populations
- Hybrid Prisma Access deployments where on-premises components must remain version-compatible with cloud components
- Environments that intentionally enabled authentication override to reduce login friction

Immediate scoping questions:

- Which GlobalProtect portals and gateways are exposed to the internet or broad partner/VPN source ranges?
- Where is authentication override enabled for portal or gateway workflows?
- What certificate is used for authentication override cookies, and is it reused by HTTPS or any other feature?
- Which devices remain on vulnerable branches below Palo Alto's fixed versions?
- Which appliances have logging retained for GlobalProtect authentication, VPN assignment, and administrator review?

Useful local pivots:

- PAN-OS configuration exports and device inventory
- GlobalProtect portal/gateway configuration records, especially cookie settings
- Certificate inventories and PKI management records
- Firewall and VPN authentication logs keyed to GlobalProtect cookie-auth events
- EDR, SIEM, and network-flow telemetry for hosts authenticating through affected gateways

8. Mitigation and Workarounds

Immediate actions:

- Upgrade every affected PAN-OS / Prisma Access branch to a vendor-supported fixed version as documented by Palo Alto.
- Identify every deployment where GlobalProtect authentication override is enabled.
- Generate a new certificate dedicated exclusively to authentication override cookies if the current certificate was reused elsewhere.
- If rapid remediation is not possible, disable authentication override on the GlobalProtect portal and gateway until the environment is safely upgraded.
- Preserve logs and supporting telemetry before making large configuration changes if compromise is suspected.

Short-term hardening:

- Verify that the certificate used for authentication override cookies is not shared with the portal HTTPS service, gateway HTTPS service, or other features.
- Reduce internet exposure and restrict administrative reachability where business operations allow.
- Confirm centralized retention of GlobalProtect authentication logs, system logs, and downstream identity/network telemetry.
- Review privileged local accounts and VPN-access policies that would increase impact if a forged cookie were accepted.

Vendor-specific operational notes:

- Palo Alto warns that users may need to re-authenticate after upgrade because cookies are regenerated more securely.
- For phased upgrades, the vendor documents a temporary CLI setting to disable strict cookie HMAC validation in mixed-version environments, but this should be treated as a transition aid rather than a long-term control.
- Hybrid Prisma Access deployments require coordinated upgrades of on-premises NGFW components to maintain compatibility.

Workaround note:

- The authoritative remediation path is Palo Alto patching and supported configuration correction.
- Disabling authentication override and isolating certificate usage are important emergency controls, but they are not substitutes for bringing the environment onto fixed releases.

9. Detection Engineering

Detection priorities: Recommended telemetry: Practical analytic themes: Illustrative detection pivots from Rapid7 reporting: Because campaign indicators may change quickly, defenders should not rely solely on these values. The strongest durable detections are cookie-auth success events, anomalous VPN access, and post-authentication behavior inconsistent with the expected user/device profile.

Signal	Telemetry Source	Analytic Goal
Successful or unusual GlobalProtect `gateway-auth,login,Cookie` events, especially for privileged or local accounts	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity

Cookie-authentication successes originating from unfamiliar infrastructure or cloud/VPS providers	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
VPN session establishment immediately following suspicious cookie-auth events	Network, auth, proxy, or service-access logs	Identify externally reachable or suspiciously accessed systems
Devices showing authentication override enabled where policy owners did not expect the feature to be active	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
New internal reconnaissance, lateral connections, or privileged access following unusual GlobalProtect authentication patterns	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity

9.1 Detection Query

```
// Internet-facing service inventory and version-discovery pivots for CVE-2026-0257 Palo Alto Networks
PAN-OS Authentication Bypass Vulnerability
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("weblogic", "panos", "litellm", "docker ps", "kubectl get pods")
| project Timestamp, DeviceName, FileName, ProcessCommandLine
| order by Timestamp desc
```

9.2 Exposure / Triage Query

```
// External exposure and suspicious follow-on activity
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443)
| project Timestamp, DeviceName, InitiatingProcessFileName, LocalIP, RemoteIP, RemotePort, RemoteUrl
| order by Timestamp desc
```

10. Threat Hunting

Hunt objectives:

- Determine which exposed GlobalProtect assets were vulnerable and misconfigured during the exploitation window.
- Identify suspicious cookie-based authentication successes dating back to at least 2026-05-13 and preferably earlier if log retention allows.
- Correlate suspicious VPN-auth activity with internal movement, privileged access, and data-system reachability.
- Distinguish unsuccessful probing from cases where an attacker established a working tunnel or otherwise authenticated successfully.

Suggested hunt questions:

- Which GlobalProtect logs show `login, Cookie` success events for unusual users, local admin accounts, or unknown devices?
- Which source IPs, machine names, or MAC-like values match the public campaign indicators or resemble them behaviorally?
- Did any suspicious cookie-auth event precede a VPN-assigned address, endpoint registration, or internal east-west traffic?
- Were there successful logins from infrastructure providers or geographies inconsistent with the organization's expected remote-access population?
- Did any PAN-OS device with authentication override enabled also reuse its cookie certificate elsewhere?

Useful local pivots:

- Historical GlobalProtect logs around 2026-05-17 onward

- Authentication records for local accounts and break-glass users
- VPN-assigned IP histories and DHCP / network-access-control logs
- EDR timelines for hosts accessed shortly after suspicious remote-access events
- PKI and configuration snapshots showing certificate reuse for authentication override

10.1 Hunt Query

```
// External exposure and suspicious follow-on activity
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443)
| project Timestamp, DeviceName, InitiatingProcessFileName, LocalIP, RemoteIP, RemotePort, RemoteUrl
| order by Timestamp desc
```

11. MITRE ATT&CK Mapping

Mapped ATT&CK techniques:

- T1190 - Exploit Public-Facing Application
- Rationale: Internet-facing GlobalProtect portals and gateways are the primary initial-access path for this KEV-listed vulnerability.
- T1133 - External Remote Services
- Rationale: Successful exploitation yields unauthorized remote-access capability through the organization's VPN edge.
- T1078 - Valid Accounts
- Rationale: Although the initial condition is an authentication bypass rather than true credential theft, the resulting access may present as a valid remote-access session and can blend into account-centric monitoring.

Interpretation:

- T1190 captures the exploitation of the exposed edge appliance.
- T1133 captures the practical outcome of gaining remote access through the VPN path.
- T1078 reflects the defensive challenge that successful cookie-based access may resemble legitimate authenticated usage in downstream telemetry.

12. Validation / Lab Testing

Safe validation steps:

- Inventory all GlobalProtect portals and gateways and confirm their PAN-OS / Prisma Access versions.
- Check whether authentication override is enabled on each portal or gateway.
- Validate whether the certificate used for authentication override cookies is unique and not reused elsewhere.
- Review retained GlobalProtect logs for successful cookie-authentication events and follow-on VPN assignments.
- Use only vendor-supported methods or safe configuration review to confirm remediation state.

Recommended validation checklist:

1. Build a complete list of PAN-OS and Prisma Access assets in scope for GlobalProtect access.
2. Verify which systems expose GlobalProtect services externally.
3. Confirm whether authentication override is enabled on each portal or gateway.
4. Validate the certificate used for authentication override and whether it is reused with HTTPS or another feature.
5. Upgrade vulnerable branches to Palo Alto's fixed versions and confirm post-upgrade user re-authentication behavior.
6. Hunt historical logs for suspicious cookie-based authentication from at least 2026-05-17 onward.
7. Conduct compromise assessment on any appliance or downstream network segment that shows suspicious successes or follow-on access.

Do not test public proof-of-concept or forged-cookie tooling against production appliances.

13. Recommended Actions Summary

Critical - Network / Security Infrastructure Owners - 24 hours Critical - Detection / SOC - 24 hours High - Identity / PKI / Platform Teams - 48 hours High - Incident Response - As needed

Priority	Owner	Action
Critical	Platform / Application Owners	Patch all affected GlobalProtect-enabled PAN-OS and Prisma Access branches to vendor-fixed versions.
Critical	Platform / Application Owners	Disable authentication override immediately where patching cannot be completed at once.
High	Security / Platform Owners	Replace any authentication-override certificate that was reused by HTTPS or another feature.
High	SOC / Detection Engineering	Hunt for successful GlobalProtect cookie-auth events, especially involving local admin accounts, unusual source infrastructure, and the public indicators listed in this report.
High	Security / Platform Owners	Correlate suspicious VPN activity with downstream internal access, lateral movement, and privileged operations.
High	Security / Platform Owners	Review certificate management practices around GlobalProtect and ensure authentication override uses a dedicated certificate.

14. References

See `references.md` for the full reference list used in this report.